

Cheatsheet Burp Suite – Laboratorio A04: Insecure Design

1. Configurazione di Burp Suite

1. Aprire Burp Suite Community Edition.
2. Avviare un progetto temporaneo (Temporary Project).
3. Nella scheda Proxy → Intercept, premere "Intercept is off".
4. Aprire il browser integrato: Proxy → Open Browser.
5. Navigare all'indirizzo:
`http://localhost:8004`

Burp ora intercetta tutto il traffico dell'applicazione.

2. Obiettivo del laboratorio

1. Manipolare parametri di business logic.
 2. Creare prenotazioni a prezzo arbitrario.
 3. Applicare più volte lo stesso coupon.
 4. Modificare prenotazioni già confermate.
 5. Creare overbooking bypassando i vincoli.
-

3. Esercizio 1: Modifica del Prezzo (Parameter Tampering)

1. Creare una nuova prenotazione dal form.
2. Nel momento in cui si invia il form, attivare l'intercetto:
Proxy → Intercept → "Intercept is on".
3. Inviare la prenotazione nella UI.
4. Burp intercetterà una richiesta POST a `create_booking.php`.
5. Cercare il parametro `total_price`.

Esempio:

```
total_price=50.00
```

6. Modificarlo a:

```
total_price=0.01
```

7. Premere "Forward".
8. Verificare nell'interfaccia che la prenotazione risulti creata con il nuovo prezzo.

4. Esercizio 2: Riutilizzo Illimitato dei Coupon

1. Effettuare una prenotazione e arrivare alla pagina in cui è possibile applicare un coupon.
2. Attivare l'intercetto.
3. Applicare il coupon dalla UI (es. WELCOME10).
4. Intercettare la richiesta a `apply_coupon.php`.
5. Inviare la richiesta a Repeater:
tasto destro → "Send to Repeater".
6. In Repeater, premere "Send" più volte.

Notare che il totale scende ogni volta.
Il sistema non ha limiti di utilizzo.

5. Esercizio 3: Modifica di Prenotazione già Confermata

1. Creare una prenotazione.
 2. Confermarla (se previsto dal flusso).
 3. Aprire "Modifica prenotazione".
 4. Attivare l'intercetto.
 5. Inviare la modifica anche se la prenotazione è confermata.
 6. Cambiare:
 - data
 - ora
 - numero ospiti
 - prezzo
 7. Forward della richiesta e verificare che la modifica sia applicata.
-

6. Esercizio 4: Cancellazione non autorizzata

1. Creare una prenotazione.
2. Nel database settare manualmente lo stato a "completed":

```
UPDATE bookings SET status='completed' WHERE id=1;
```

- 1.
2. Tornare nella UI e cliccare "Cancella".
3. Attivare l'intercetto se necessario.

4. Osservare che il sistema permette la cancellazione anche se la prenotazione è completata.

7. Esercizio 5: Overbooking (Bypass Capacità Massima)

1. Selezionare un servizio con capacità limitata.
2. Aprire il form di prenotazione.
3. Con gli strumenti sviluppatore del browser modificare il campo:

`number_of_guests`

- 1.
2. Impostare un valore superiore alla capacità (es. 10 invece di 4).
3. Attivare l'intercept e inviare la richiesta.
4. Il server accetterà la prenotazione senza controllare la disponibilità.

8. Utilizzo di Burp Repeater come Strumento Principale

Per ogni vulnerabilità logica, Repeater è lo strumento ideale.

Per spostare una richiesta su Repeater:

1. Tasto destro sulla richiesta nel Proxy → "Send to Repeater".
2. Nella scheda Repeater, modificare i parametri.
3. Premere "Send" per rieseguire la richiesta infinite volte.
4. Osservare la risposta del server nel pannello destro.

Questo è fondamentale per:

- riapplicare un coupon più volte,

- eliminare o modificare prenotazioni indipendentemente dalla UI,
 - bypassare limiti di disponibilità e capacità.
-

9. Cosa si deve imparare da questo laboratorio

1. Lato client non è affidabile: ogni campo può essere manipolato.
 2. Le regole di business devono essere implementate lato server.
 3. Gli scanner automatici non trovano vulnerabilità di design.
 4. Il proxy è fondamentale per analizzare la logica applicativa.
 5. La sicurezza non è solo input validation, ma anche flusso e logica.
-

10. Suggerimenti per un uso corretto di Burp Suite

- Disattivare l'Intercept quando non serve.
- Usare Repeater per test ripetuti e precisi.
- Usare "Search" per trovare rapidamente parametri vulnerabili.
- Osservare attentamente la differenza tra richiesta e risposta.
- Confrontare cosa la UI consente con cosa il server accetta realmente.